

**PYTHON BACKEND / KURS ISHI**

# Professional Code Review

Senior software engineer mezonlari asosida dalilli baholash



OnlinePharmacy kurs ishi uchun katta va funksional bazaga ega: Django app'lar ajratilgan, migratsiyalar, testlar, checkout tranzaksiyasi, CI va Docker konfiguratsiyasi mavjud. 92 ta mavjud test izolyatsiyalangan muhitda o'tdi. Biroq payment webhook imzosiz so'rovni qabul qilishi, delivery endpointlarining mavjud bo'lmagan Order.driver fieldiga tayanishi, object-level permission va doim xato qaytaradigan auth/category oqimlari loyihani hozircha texnik intervyuga tavsiya qilishga to'sqinlik qiladi.

|          |                                                                                                                                      |          |                                                                  |
|----------|--------------------------------------------------------------------------------------------------------------------------------------|----------|------------------------------------------------------------------|
| O'QUVCHI | <b>Yoldoshev Firdavs</b>                                                                                                             | SANA     | <b>2026-09-09</b>                                                |
| LOYIHA   | <b>OnlinePharmacy</b>                                                                                                                | SCOPE    | <b>Python/Django backend asosiy; frontend bahoga kiritilmadi</b> |
| MANBA    | <a href="https://github.com/YoldoshevFirdavs/OnlinePharmacy">https://github.com/YoldoshevFirdavs/OnlinePharmacy</a> (commit 778b003) | REVIEWER | <b>Komiljon Xamidjonov</b>                                       |

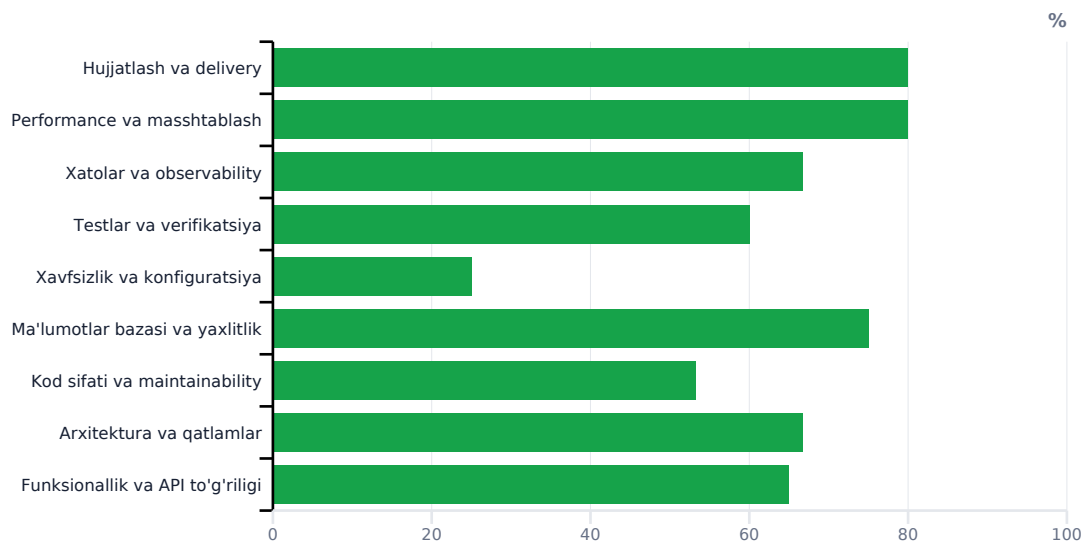
**KUCHLI TOMONLAR**

- + Loyiha users, pharmacy, orders, billing, dashboard va security kabi tushunarli Django app'larga ajratilgan.
- + CheckoutAPIView transaction.atomic va select\_for\_update orqali stock race-condition'ini kamaytiradi, narxni serverdagi product qiymatidan hisoblaydi.
- + 92 ta mavjud Django testi SQLite/locmem review muhitida muvaffaqiyatli o'tdi; makemigrations --check yangi migratsiya talab qilmadi.
- + JWT, OTP, throttling, audit log, ban tizimi, pagination, CI va Docker kabi junior kurs ishidan kengroq infratuzilma ko'zda tutilgan.
- + Repository secret scanida real production kalitlari topilmadi; .env va .env.prod gitignore orqali chiqarilgan.

**Keyingi texnik intervyu bosqichiga o'tishga tavsiya  
qilinmadi**

# 01. Ballar xaritasi

Har bir ustun shu kriteriyada olingan ballning maksimal ballga nisbati.



| Funksionallik va API to'g'riligi | 13 / 20 | Asosiy storefront va checkout bor; delivery, cookie refresh va category mutation oqimlari buzilgan.                              |
|----------------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------|
| Arxitektura va qatlamlar         | 10 / 15 | Django app'lar domenlarga ajratilgan, ammo yirik views fayllari va parallel/duplikat oqimlar couplingni oshirgan.                |
| Kod sifati va maintainability    | 8 / 15  | Nomlash va struktura qisman yaxshi; juda katta funksiyalar, takroriy kod va 242 ta broad exception mavjud.                       |
| Ma'lumotlar bazasi va yaxlitlik  | 9 / 12  | Migratsiya, indeks va checkout locklari yaxshi; delivery model kontrakti va karta ma'lumoti modeli xavfli.                       |
| Xavfsizlik va konfiguratsiya     | 3 / 12  | Env va admin permissionlari bor, lekin webhook bypass hamda bir nechta object-level authorization kamchiligi kritik.             |
| Testlar va verifikatsiya         | 6 / 10  | 92 test o'tdi; kritik payment/delivery/permission ssenariylari yo'q va ayrim assertlar natijani tekshirmaydi.                    |
| Xatolar va observability         | 4 / 6   | Logging va redaction mavjud; broad except/pass va str(e) response'lari diagnostikani yashiradi yoki ichki xatoni ochadi.         |
| Performance va masshtablash      | 4 / 5   | Pagination, indeks, select_related va stock locking ishlatilgan; ayrim N+1 va takroriy query xavflari qolgan.                    |
| Hujjatlash va delivery           | 4 / 5   | README, CI, Docker va env namuna bor; dependency nomi/versiyasi va production health/security sozlamalari to'liq ishonchli emas. |

## 02. Muhim topilmalar

| CRITICAL | 1. Stripe webhook secret bo'lmasa imzosiz payload qabul qilinadi                                                                                                                                                                                        |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL    | billing/views.py:195-217; config/settings.py:346-349; .env.example:28-31                                                                                                                                                                                |
| TA'SIR   | STRIPE_WEBHOOK_SECRET settingsga umuman yuklanmagan. Istalgan tashqi so'rov checkout.session.completed JSON yuborib, mavjud orderni Paid holatiga o'tkaza oladi. Izolyatsiyalangan regression testda bu holat qayta yaratildi.                          |
| YECHIM   | STRIPE_WEBHOOK_SECRETni majburiy env setting qiling; bo'sh bo'lsa startupni to'xtating va webhookni rad eting. Faqat stripe.Webhook.construct_event orqali tasdiqlangan eventni qayta ishlang; valid, invalid va missing-signature testlarini qo'shing. |

| CRITICAL | 2. Delivery API mavjud bo'lmagan Order.driver fieldiga tayanadi                                                                                                                                                                       |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL    | orders/views.py:151-165,197-207; orders/models.py:25-51,67-75                                                                                                                                                                         |
| TA'SIR   | Driver order list/status filtri FieldError beradi, accept oqimi esa AttributeError bilan yiqiladi yoki assignmentni DBga yozmaydi. Runtime tekshiruvda field resolve xatosi tasdiqlandi; delivery asosiy oqimi ishlamaydi.            |
| YECHIM   | Bitta kanonik model tanlang: Orderga aniq driver FK qo'shing yoki barcha viewlarni DeliveryOrder orqali ishlatang. Migratsiya yarating va accept, competing accept, status ownership hamda persistence integration testlarini yozing. |

| HIGH   | 3. Legacy charge endpoint boshqa foydalanuvchi orderini owner tekshiruviz o'zgartiradi                                                                                             |
|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | billing/views.py:21-50                                                                                                                                                             |
| TA'SIR | Authenticated foydalanuvchi begona order_id yuborib o'sha order uchun charge ochishi va statusni Paid qilishi mumkin. Regression testda boshqa user orderi o'zgargani tasdiqlandi. |
| YECHIM | Orderni id va user=request.user bilan oling yoki admin policy qo'llang. Legacy Charges API'ni olib tashlashni ko'rib chiqing; object ownership va idempotency testlarini yozing.   |

| HIGH   | 4. ReviewViewSet boshqa foydalanuvchi review'ini tahrirlash yoki o'chirishga ruxsat beradi                                                                                  |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | pharmacy/views/product.py:93-101; pharmacy/serializers/misc.py:38-43                                                                                                        |
| TA'SIR | IsAuthenticatedOrReadOnly faqat loginni tekshiradi; update/destroy uchun queryset barcha reviewlarni qaytaradi. Regression testda attacker boshqa user matnini o'zgartirdi. |
| YECHIM | IsOwnerOrReadOnly object permission yozing, staff istisnosini aniq belgilang va querysetni action bo'yicha cheklang. Update/delete ownership testlarini qo'shing.           |

| HIGH   | 5. Category mutation permission class instance emas                                                                                                                                                    |
|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | pharmacy/views/product.py:83-90                                                                                                                                                                        |
| TA'SIR | get_permissions [IsAuthenticated] classini qaytaradi, DRF esa has_permission chaqirig'ida TypeError beradi. Create/update/delete category endpointlari 500 bilan yiqiladi; runtime testda tasdiqlandi. |
| YECHIM | [IsAuthenticated()] qaytaring, lekin biznes nuqtayi nazaridan IsAdminUser yoki katalog boshqaruvchisi permissionini qo'llang. Har bir mutation uchun 401/403/2xx test yozing.                          |

| HIGH   | 6. Cookie refresh endpoint ataylab exception chiqaradi                                                                                                                                    |
|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | users/views.py:1403-1423                                                                                                                                                                  |
| TA'SIR | Refresh cookie mavjud bo'lsa ham endpoint har safar 401 qaytaradi; frontend token yangilash oqimi uziladi va foydalanuvchi qayta login qilishga majbur bo'ladi.                           |
| YECHIM | RefreshToken orqali tokenni validatsiya va rotate/blacklist qiling; cookie Secure, HttpOnly, SameSite va CSRF modelini aniq belgilang. Expired, revoked va valid token testlarini yozing. |

| MEDIUM | 7. Testlar soni yaxshi, lekin muhim testlar soxta yashil natija beradi                                                                                                                                                   |
|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | orders/tests/test_orders_api.py:108-129; pharmacy/tests/test_products_api.py:185-192                                                                                                                                     |
| TA'SIR | Bir test expected_totalni hisoblaydi, lekin assert qilmaydi; boshqasi faqat response 200 bo'lsa tekshiradi; yana biri 'or True' bilan doim o'tadi. Payment webhook, delivery contract va review ownership testlari yo'q. |
| YECHIM | Shartli/no-op assertlarni qat'iy assertionga almashtiring. P0 xavflar uchun regression testlar yozing va PostgreSQL/Redis bilan CI'da pytest discovery natijasini barqaror qiling.                                       |

| MEDIUM | 8. Dependency va production setup qayta tiklanishi ishonchli emas                                                                                                                         |
|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | requirements.txt:10,35; docker-compose.prod.yml:63-68; config/urls.py:51-102                                                                                                              |
| TA'SIR | psycopg2-binary 2.9.7 Python 3.12da pg_config talab qilib installni buzdi; 'csp' nomi django-csp o'rniga boshqa katta paketni o'rnatadi; production healthcheck URL routingda ko'rinmadi. |
| YECHIM | Qo'llab-quvvatlanadigan Python versiyasini aniq lock qiling, psycopg wheelini moslang, csp o'rniga kerak bo'lsa django-csp ishlatib va real /api/v1/health/ endpoint testini qo'shing.    |

| MEDIUM | 9. Sensitive karta maydonlari modelda plaintext saqlashga tayyor                                                                                                           |
|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | users/models.py:185-202                                                                                                                                                    |
| TA'SIR | Seller modelidagi to'liq karta raqami va expiry maydonlari kelajakda to'ldirilsa PCI va ma'lumot sizishi xavfini oshiradi, hatto hozir serializerda ochilmagan bo'lsa ham. |
| YECHIM | PAN/expiry saqlamang; Stripe Connect yoki payment provider token/PaymentMethod ID saqlang. Eski ma'lumot bo'lsa xavfsiz migratsiya va o'chirish rejasini tuzing.           |

| MEDIUM | 10. Yirik modullar va broad exceptionlar maintainabilityni pasaytiradi                                                                                                                                       |
|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DALIL  | dashboard/views.py:1-2374; users/views.py:1-2092; repository-wide runtime scan                                                                                                                               |
| TA'SIR | Backendda 242 ta broad except/except Exception holati va 80+ qatorli ko'p funksiyalar bor. Xatolar yutiladi, API ichki exception matnlarini qaytaradi va parallel OTP/service oqimlari bir-biridan ajraladi. |
| YECHIM | Viewlarni use-case/service qatlamiga bo'ling, domen exceptionlarini ajrating, bare except/passni logging va aniq exceptionlar bilan almashtiring. Avval payment, delivery va OTP oqimlaridan boshlang.       |

## 03. Backend checklist

| Backend syntax va Django check   | <b>PASS</b>   | compileall va manage.py check muvaffaqiyatli.                               |
|----------------------------------|---------------|-----------------------------------------------------------------------------|
| Product va checkout asosiy oqimi | <b>PASS</b>   | Public listing va atomik checkout implementatsiyasi mavjud.                 |
| Delivery oqimi                   | <b>FAIL</b>   | Viewlar Order.driverga murojaat qiladi, modelda field yo'q.                 |
| Payment webhook verifikatsiyasi  | <b>FAIL</b>   | Secret yo'q bo'lsa imzosiz event qabul qilinadi.                            |
| Object-level authorization       | <b>FAIL</b>   | Legacy charge va review mutationda owner tekshiruvi yetishmaydi.            |
| JWT va OTP                       | <b>QISMAN</b> | Asosiy mexanizmlar bor; cookie refresh doim xato qaytaradi.                 |
| Database migratsiyalari          | <b>PASS</b>   | Barcha migratsiyalar qo'llandi va yangi migration talab qilinmadi.          |
| Automated tests                  | <b>QISMAN</b> | 92 test o'tdi, lekin kritik negative/security coverage yetarli emas.        |
| Secret management                | <b>PASS</b>   | Real kalit topilmadi, env fayllar ignore qilingan.                          |
| CI, Docker va delivery           | <b>QISMAN</b> | Konfiguratsiyalar mavjud, ammo dependency va healthcheck nomuvofiqligi bor. |
| Frontend                         | <b>N/A</b>    | Ushbu review scope'iga kiritilmadi.                                         |

## Amalda bajarilgan tekshiruvlar

| Tekshiruv                        | Natija         | Tafsilot                                                                                                                 |
|----------------------------------|----------------|--------------------------------------------------------------------------------------------------------------------------|
| python -m compileall             | <b>PASSED</b>  | Backend Python fayllarida syntax xatosi aniqlanmadi.                                                                     |
| python manage.py check           | <b>PASSED</b>  | Django system check: 0 issue.                                                                                            |
| Django test suite                | <b>PASSED</b>  | 92 test SQLite/locmem izolyatsiyalangan review muhitida o'tdi; real PostgreSQL/Redis tekshirilmagan.                     |
| Targeted regression tests        | <b>FAILED</b>  | 5/5 test mavjud nuqsonlarni qayta yaratdi: unsigned webhook, cross-user charge/review, category crash va delivery crash. |
| makemigrations --check --dry-run | <b>PASSED</b>  | No changes detected.                                                                                                     |
| manage.py check --deploy         | <b>WARNING</b> | HSTS, SSL redirect va secure cookie bo'yicha 4 warning; qismi env/proxy orqali boshqariladi.                             |
| requirements install             | <b>WARNING</b> | Deklaratsiyadagi psycpg2-binary 2.9.7 Python 3.12da o'rnatilmadi; review uchun 2.9.10 ishlatildi.                        |
| Secret va repository scan        | <b>PASSED</b>  | Tracked fayllarda real live token/key topilmadi; .env ignore qilingan.                                                   |

## 04. AI yordamida yozilgan kod ehtimoli

TAXMINIY DIAPAZON

**50-70%**

ISHONCH

**MEDIUM**

### Kuzatilgan signallar

- + Commit 9704cfa metadata'sida Copilot aniq co-author sifatida ko'rsatilgan.
- + Initial commit 71 984 qator, keyingi ayrim commitlar 10-17 ming qatorlik katta bloklar bilan kiritilgan.
- + Kodda ko'p 'FIXED/ADDED/Enhanced' izohlari, parallel OTP/payment oqimlari va model-view kontrakti nomuvofiqligi bor.
- + Ko'p test/docstringlar shablon ko'rinishida; ayrim testlar 'or True' yoki shartli assert bilan real natijani tekshirmaydi.

### Cheklov

Kod va commit tarixidan AI yozgan ulushni aniq o'lchab bo'lmaydi. Bu diapazon faqat kuzatilgan signallar asosidagi pedagogik taxmin; AI ishlatilgani uchun ball pasaytirilmagan.

### Kod egaligini tekshirish uchun savollar

- + Stripe webhook secret bo'lmasa nima uchun requestni rad etish kerak va buni test bilan qanday isbotlaysiz?
- + Order va DeliveryOrder o'rtasidagi driver bog'lanishini bitta kanonik modelga qanday o'tkazasiz?
- + ReviewViewSet uchun object-level permissionni yozib, attacker testi bilan ko'rsating.
- + Checkoutdagi select\_for\_update qaysi race-conditionni hal qiladi va qachon yetarli bo'lmaydi?
- + users/views.py va OTP servislarini kichik use-case'larga qanday refactor qilasiz?

Eslatma: bu baho plagiat hukmi emas. Koddan foydalanish usuli emas, natijaning sifati va o'quvchining tushunishi baholanadi.

## 05. Rivojlanish rejasi

| <b>P0</b> | Stripe webhook va legacy charge authorizationni yopish              | Missing/invalid signature 400 qaytaradi; begona order o'zgarmaydi; idempotent payment testlari o'tadi.               |
|-----------|---------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| <b>P0</b> | Delivery model-view kontraktini tiklash                             | Driver accept/list/status DBda saqlanadi; ikki driver parallel accept qilganda faqat bittasi yutadi.                 |
| <b>P1</b> | Review ownership, category permission va cookie refreshni tuzatish  | Unauthorized mutation 403, category admin flow 2xx va valid refresh yangi token qaytaradi.                           |
| <b>P1</b> | Kritik negative regression testlarni CI'ga qo'shish                 | Payment, delivery, permission va rollback testlari PostgreSQL/Redis service bilan har pushda o'tadi.                 |
| <b>P2</b> | Yirik views/OTP modullarini refactor va dependencylarni lock qilish | Use-case'lar kichik servislar bilan ajratilgan, broad exceptions kamaygan va clean environment install takrorlanadi. |

## Yakuniy qaror

**Keyingi texnik intervyu bosqichiga o'tishga tavsiya qilinmadi**

**61/100. Loyiha kuchli va katta baza ko'rsatadi, ammo payment xavfsizligi hamda delivery asosiy oqimidagi ikki majburiy blocker tuzatilmaguncha texnik intervyuga o'tkazish tavsiya etilmaydi. P0 tuzatishlar va regression testlardan so'ng qayta review qilish kerak.**

## Texnik intervyuda tekshiriladigan mavzular

- + Stripe webhook verification va idempotency
- + Object-level authorization
- + Django transaction va select\_for\_update
- + Model-view contract
- + Test quality va negative cases

**Code Reviewer: Komiljon Xamidjonov**

Codify Tech MCHJ